

Report Creazione di una regola Firewall

Consegna S3L5

1. Obiettivo

L'obiettivo creare una regola firewall che blocchi l'accesso alla DVWA (su metasploitable) dalla macchina Kali Linux e ne impedisca di conseguenza lo scan. Un requisito fondamentale dell'esercizio è che le macchine Kali e Metasploitable siano su reti diverse, potete aggiungere una nuova interfaccia di rete a pfSense in modo tale da gestire una ulteriore rete.

1.2 — Pre-requisiti: — pfSense MV

Il prerequisito per poi svolgere la consegna era installare pfSense, incontrando il primo ostacolo, ovvero un **kernel panic** subito al boot di pfSense. Il sistema anche avviandosi, subito dopo il caricamento dei moduli del kernel FreeBSD, crashava, dando il seguente messaggio di

```
Fatal trap 12: page fault while in kernel mode
fault virtual address = 0xffffe006cbe6000
fault code           = supervisor read data, page not present
current process      = 2049 (zfs)
panic: page fault
KDB: enter: panic
```

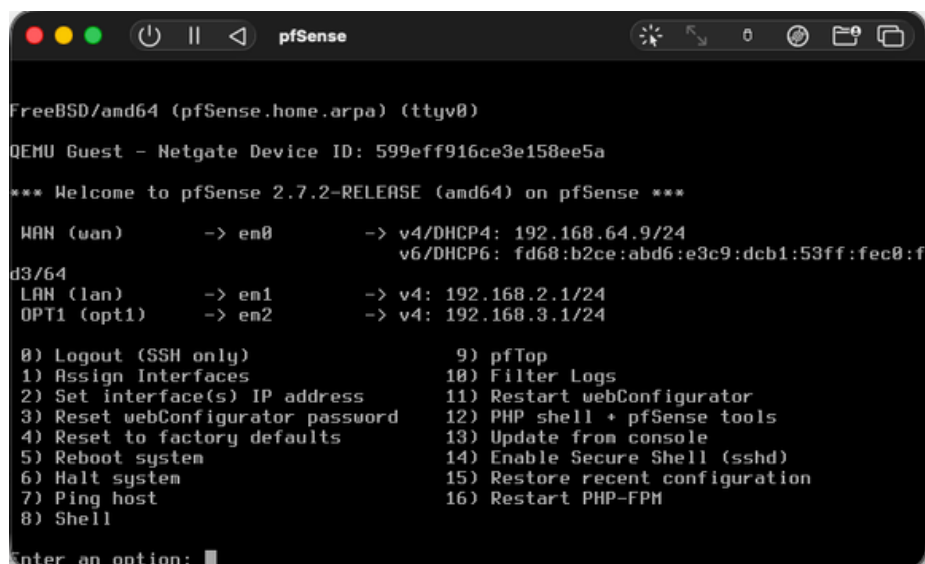
Questo crash veniva causato dal processo ZFS, andando in conflitto con UTM (avendo un MacBook Air M4).

Per ovviare al problema ho proceduto a scaricare e sostituire **pfSense 1.1.1** con la versione **pfSense 2.7.2 CE**, selezionando **UFS** come filesystem al posto ZFS, potendo procedere all'installazione di psSense e non riscontrando più errori.

1.3 — Pre-requisiti: — pfSense [Schede di rete]

In questa fase ho configurato le schede di rete.

pfSense ha bisogno almeno di due interfacce, una WAN e una LAN, quindi dopo aver spento la VM, ho aggiunto fisicamente da UTM le schede di rete, per poi procedere alla configurazione tramite pfSense.



```
FreeBSD/amd64 (pfSense.home.arpa) (ttyv0)
QEMU Guest - Netgate Device ID: 599eff916ce3e158ee5a
*** Welcome to pfSense 2.7.2-RELEASE (amd64) on pfSense ***

WAN (uan)      -> em0      -> v4/DHCP4: 192.168.64.9/24
                                v6/DHCP6: fd68:b2ce:abd6:e3c9:dcb1:53ff:fec8:f
d3/64
LAN (lan)      -> em1      -> v4: 192.168.2.1/24
OPT1 (opt1)    -> em2      -> v4: 192.168.3.1/24

0) Logout (SSH only)          9) pfTop
1) Assign Interfaces          10) Filter Logs
2) Set interface(s) IP address 11) Restart webConfigurator
3) Reset webConfigurator password 12) PHP shell + pfSense tools
4) Reset to factory defaults    13) Update from console
5) Reboot system               14) Enable Secure Shell (sshd)
6) Halt system                 15) Restore recent configuration
7) Ping host                   16) Restart PHP-FPM
8) Shell

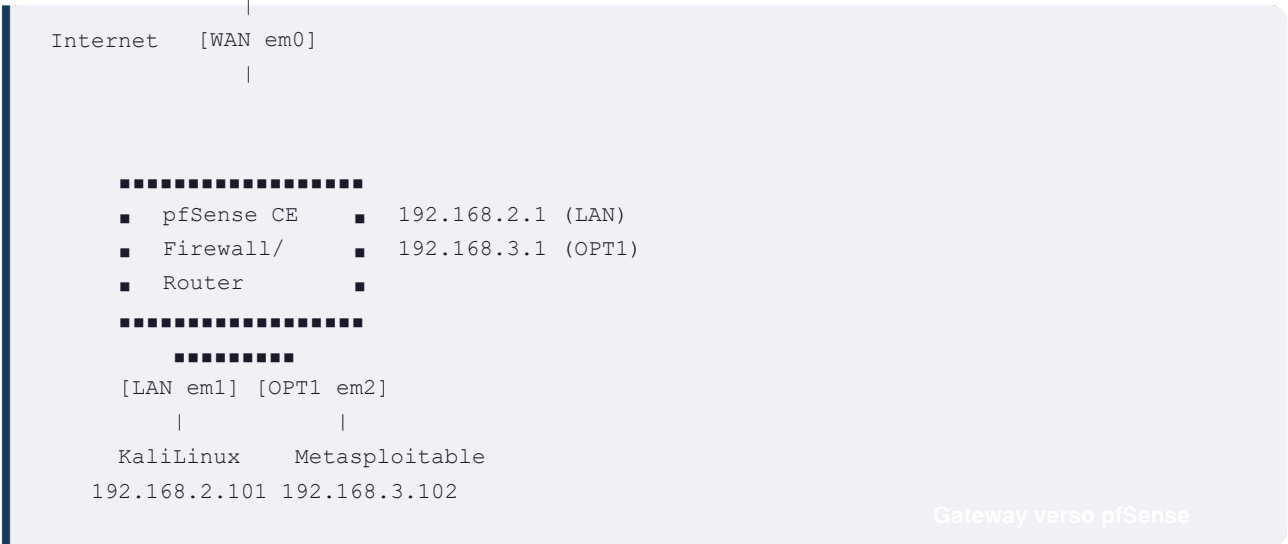
Enter an option: 
```

Dopo aver configurato sulla VM, ho spento la stessa per andare configurare nelle impostazione della VM e ho configurato le *Schede di Rete* in *Rete Condivisa*, andando ad assegnare gli indirizzi necessari, perché UTM non riesce a configurare tutto da solo

Interfaccia pfSense	Modalità UTM	Scopo
em0 (WAN)	Bridged	Connessione verso l'esterno (upstream)
em1 (LAN)	Rete Condivisa	Rete interna di Kali Linux — 192.168.2.0/24
em2 (OPT1)	Rete Condivisa	Rete interna di Metasploitable — 192.168.3.0/24

L'unica postilla che devo fare:
UTM crea problemi a em0(WAN) anche avendola configurata in DHCP, quindi per ovviare al problema, ho configurato nelle impostazioni la prima *Scheda di Rete* in Rete condivisa, riuscendo a configurare la WAN in DHCP come nello screenshot sopra.

2. Topologia di Rete creata



Macchina	IP Address	Rete	— (è il gateway)
pfSense (LAN)	192.168.2.1	192.168.2.0/24	— (è il gateway)
pfSense (OPT1)	192.168.3.1	192.168.3.0/24	192.168.2.1
Kali Linux	192.168.2.101	LAN	192.168.3.1
Metasploitable	192.168.3.102	OPT1	

Un dettaglio importante emerso durante la configurazione: sia Kali che Metasploitable avevano inizialmente il gateway impostato su indirizzi errati assegnati dal DHCP di QEMU (192.168.2.100 e 192.168.3.100 rispettivamente), anziché sugli IP delle interfacce pfSense. È stato necessario correggere manualmente le route su entrambe le macchine per permettere la comunicazione inter-rete attraverso pfSense.

3. Accesso alla WebGUI di pfSense

Per poter accedere alla WebGUI di pfSense ho assegnare a Kali un indirizzo IP della stessa rete di LAN di pfSense (192.168.2.0), con default gateway l'indirizzo di IP di pfSense (192.168.2.1), utilizzando i seguenti programmi, rimuovendo quelli che la macchina Kali avesse di default appena accesa:

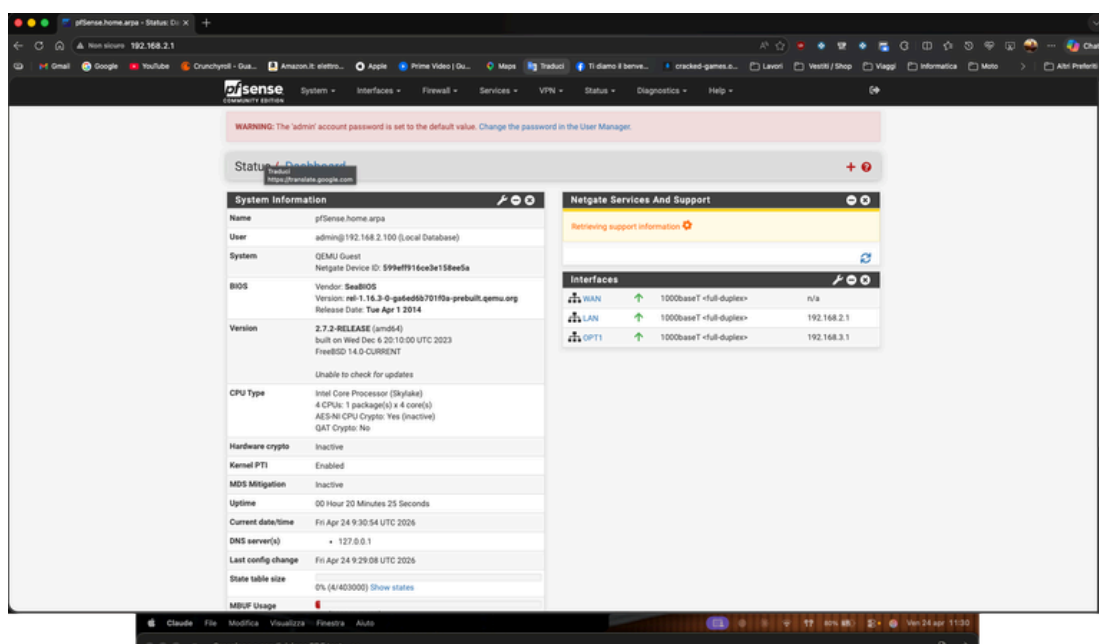
- `sudo ip addr del indirizzo_di_kali/24 dev eth0`
- `sudo ip addr add 192.168.2.101`
- `sudo route del default`
- `sudo route add default gw 192.168.31`

Riuscendo così ad entrare nella WebGUI di pfSense
Questo step l'ho emulato anche per Metasploitable

```
msfadmin@metasploitable:~$ ip route
192.168.3.0/24 dev eth0 proto kernel scope link src 192.168.3.102
default via 192.168.3.1 dev eth0
msfadmin@metasploitable:~$ ifconfig
eth0:
    Link encap:Ethernet  HWaddr f6:5a:95:11:b2:c8
    inet addr:192.168.3.102 Bcast:192.168.3.255 Mask:255.255.0
    inet6 addr: fda8:a5fe:25cf:c2:f45a:95ff:fe11:b2cb/64 Scope:Global
    UP BROADCAST RUNNING MULTICAST  MTU:1500 Metric:1
    RX packets:428 errors:0 dropped:0 overruns:0 frame:0
    TX packets:352 errors:0 dropped:0 overruns:0 carrier:0
    collisions:0 txqueuelen:1000
    RX bytes:58680 (57.3 KB)  TX bytes:62019 (60.5 KB)
    Base address:0xc000 Memory:febc0000-febe0000

lo:
    Link encap:Local Loopback
    inet addr:127.0.0.1 Mask:255.0.0.0
    inet6 addr: ::1/128 Scope:Host
    UP LOOPBACK RUNNING  MTU:16436 Metric:1
    RX packets:1501 errors:0 dropped:0 overruns:0 frame:0
    TX packets:1501 errors:0 dropped:0 overruns:0 carrier:0
    collisions:0 txqueuelen:0
    RX bytes:710481 (693.8 KB)  TX bytes:710481 (693.8 KB)

msfadmin@metasploitable:~$
```



4. Creazione delle regole del Firewall

Da questo momento in poi son riuscito a procedere con la parte centrale di questa esercitazione: *la creazione di una regola firewall che bloccasse il traffico da Kali verso la DVWA su Meta.*

Per poter configurare in pfSense, le regole son dovuto andare sulla sezione “Firewall” → Rules

Ho cominciato a configurare le regole:

- La prima regola che ho impostato, tralasciando quelle che pfSense inserisce definitivamente come la “Default allow LAN to any rule” che permette tutto il traffico proveniente della rete LAN verso qualsiasi destinazione; è stata la regola che ci permettesse la comunicazione tra le due reti quindi da LAN a OPT1.

Questa regola dice che: *qualsiasi traffico che arriva dalla rete 192.168.2.0/24 e sia diretto verso 192.168.3.0/24, fallo passare*

Action
Choose what to do with packets that match the criteria specified below.
 Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP port unreachable for UDP) is returned to the sender, whereas with block the packet is dropped silently. In either case, the original packet is discarded.

Disabled ☐ **Disable this rule**
Set this option to disable this rule without removing it from the list.

Interface
Choose the interface from which packets must come to match this rule.

Address Family
Select the Internet Protocol version this rule applies to.

Protocol
Choose which IP protocol this rule should match.

Source
☐ **Invert match** /

Destination
☐ **Invert match** /

Extra Options
☐ **Log** ☐ **Log packets that are handled by this rule**
Hint: the firewall has limited local log space. Don't turn on logging for everything. If doing a lot of logging, consider using a remote syslog server (see the Status: System Logs: Settings page).

Description
A description may be entered here for administrative reference. A maximum of 52 characters will be used in the ruleset and displayed in the firewall log.

- La seconda regola è stata invece di impostare su OPT1 la stessa regola di default di LAN “Default allow OPT1 to any rule”
- La terza regola, sempre su OPT1 è stata la stessa regola che ho impostato su LAN ma invertendo la sorgente e la destinazione, in questo modo ho permesso la comunicazione da OPT1 a LAN.

Grazie a queste due regole impostate, son riuscito a pingare da Metasploitable a Kali Linux e viceversa questa

4.1 — Creazione delle regole: — Blocco da Kali verso DVWA Meta

In questa fase sono andato a impostare la regola, che mi permettesse di impostare il blocco richiesto dalla consegna, quindi il traffico da Kali verso DVWA su Metasploitable.

Per impostare la seguente regola sono andato intanto su *Rules* → *LAN*

Da qui ho cominciato ad impostare la regola che ci servirà per applicare il blocco:

- per prima cosa andremo ad impostare come azione “Block” che ci fungerà come scarto del pacchetto
- su interface imposteremo ovviamente LAN ovvero l’interfaccia da cui arriva il traffico di Kali
- come address family gli indirizzi IPv4
- come protocollo lascio TCP perché un blocco sul protocollo HTTP che sta su TCP
- come sorgente andremo ad impostare Network l’indirizzo 192.168.2.101/24 ovvero l’indirizzo IP di Kali
- come destinazione OPT2 subnets sempre Network l’indirizzo 192.168.3.102/24 ovvero l’indirizzo IP di Meta
- sulla porta di destinazione impostiamo solo quella di HTTP ovvero quella (80)
- aggiungendo poi come descrizione una che mi permetta di riconoscere la stessa.

Grazie a questa regola abbiamo al firewall: *Se Kali (avente come indirizzo IP 192.168.2.101) tenta di raggiungere Metasploitable (avente come indirizzo IP 192.168.3.102) sulla porta 80 via TCP, scarta il pacchetto senza dire nulla.*

Per poter confermare tutte le regole impostare sulla GUI ho cliccato **Apply Changes** per rendere effettive così tutte le modifiche effettuate.

5. Verifica del Funzionamento di tutta la configurazione

Da qui in avanti ho cominciato a verificare il funzionamento di tutte le configurazioni effettuate

Il primo test effettuato è stata quella di tentare una connessione HTTP alla porta 80 di Meta usando la curl.

Il risultato è stato quello atteso, dopo circa 2 minuti, ho ottenuto lo stato di timeout, andando a confermare che pfSense sta scartando i pacchetti (regola di blocco)

```
(kali@kali)-[~]  
$ curl http://192.168.3.102/dvwa  
curl: (28) Failed to connect to 192.168.3.102 port 80 after 133533 ms: Could not connect to server
```

5.1 — Secondo Test — Scansione della porta (porta HTTP 80)

Il secondo test che ho effettuato è stata la scansione della porta 80 su Meta.

Tramite il comando,

```
nmap -p 80 192.168.3.102
```

ho ottenuto come risultato anche qui quello atteso, ovvero che **nmap** riportando la porta 80 la rileva filtrata "filtered", quindi sta dicendo in modo esplicito la presenza di un firewall che sta bloccando attivamente i pacchetti verso la porta che abbiamo impostato prima ovvero la 80.

```
(kali@kali)-[~]  
$ nmap -p 80 192.168.3.102  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-24 15:57 -0400  
Nmap scan report for 192.168.3.102  
Host is up (0.0072s latency).  
PORT      STATE SERVICE  
80/tcp    filtered http  
Nmap done: 1 IP address (1 host up) scanned in 0.88 seconds
```

6. Conclusioni

Grazie a questa esercitazione, sono riuscito a capire il funzionamento di un firewall (pfSense), come funzionassero le regole di un firewall.

La difficoltà iniziale è stata la configurazione pfSense in UTM, per problematiche di virtualizzazione con il mio dispositivo con Apple Silicon (MacBook Air M4), ma sono riuscito ad ottenere il risultato atteso.

pfSense gestisce il routing tra le due reti separate

- 192.168.2.1
- 192.168.3.1

e le regole del firewall garantiscono, che riescono a garantire che solo il traffico che è autorizzato, sempre grazie alle stesse, riesca a transitare tra di loro.